

Fintech & Banca

Adecuación operativa al nuevo marco de protección de datos personales

KYC biométrico, scoring automatizado y datos financieros bajo el nuevo estándar de responsabilidad proactiva.

01-12-2026 Vigencia plena Régimen sancionatorio operativo	20.000 UTM Multa gravísima ~\$1.400 millones aprox.	+50% Recargo Si no subsana en 60 días
--	--	--

Datos clave del nuevo régimen

■ Vigencia plena

1 de diciembre de 2026

■ Notificación de brechas

Sin dilaciones indebidas a la Agencia y a los afectados

■ Delegado de Protección de Datos (DPO)

Generalmente voluntario (Art. 50); obligatorio por excepción legal

■ Reincidencia (grandes empresas)

Hasta 2%–4% de los ingresos brutos anuales

■ Recargo por no subsanar

50% adicional si no corrige en 60 días

Resumen ejecutivo

Lo esencial en 30 segundos

El KYC biométrico (huella, rostro, voz) es tratamiento masivo de datos sensibles: exige DPIA previa y consentimiento expreso documentado. Los clientes tienen derecho a no ser decididos por algoritmos: explicabilidad, intervención humana e impugnación (Art. 8 bis). Las deudas prescritas deben suprimirse proactivamente de boletines comerciales; pagada la deuda, el dato se elimina en plazo legal. Se prohíbe exigir datos económicos/comerciales en selección laboral, admisión escolar o urgencia médica. El DPO es obligatorio para bancos, AFPs, aseguradoras y fintech con perfilamiento masivo; debe estar registrado ante la APDP.

1. KYC biométrico como tratamiento masivo de datos sensibles

En el ecosistema financiero moderno, la recolección de patrones biométricos (huella dactilar, reconocimiento facial o de voz) para el enrolamiento digital, autenticación de transacciones y prevención de fraudes (KYC — Know Your Customer) es una práctica generalizada. La Ley 21.719 clasifica los datos biométricos como datos personales sensibles. Su tratamiento sistemático a gran escala obliga expresamente a realizar una Evaluación de Impacto en Protección de Datos (EIPD/DPIA) previa al despliegue de las herramientas de software correspondientes. El uso de biometría sin consentimiento expreso previo o sin una justificación de seguridad documentada expone a las fintech y bancos a infracciones gravísimas con multas de hasta 20.000 UTM.

2. El derecho de impugnación ante decisiones automatizadas

El artículo 8 bis consagra un derecho fundamental clave para los consumidores financieros: el derecho a oponerse y no ser objeto de decisiones individuales basadas únicamente en tratamientos automatizados, incluida la elaboración de perfiles, que produzcan efectos jurídicos sobre ellos o les afecten significativamente. Esto impacta directamente a modelos analíticos y de software que deciden automáticamente: Scoring crediticio: algoritmos de evaluación automatizada que aprueban o rechazan solicitudes de crédito sin revisión de un analista humano. Sistemas de pricing dinámico: algoritmos que fijan tasas de interés o primas de seguros en base a perfiles de riesgo predictivos individuales. Salvaguardas mandatadas por ley (Art. 8 bis inciso final) Ante decisiones automatizadas de este tipo, la entidad financiera debe garantizar de forma transparente: el derecho a recibir información clara sobre la lógica algorítmica aplicada, el derecho a obtener una explicación comprensible, el derecho a solicitar intervención humana y un canal rápido para impugnar el resultado de la máquina.

3. Datos de obligaciones económicas, financieras y comerciales

Los artículos 17, 18 y 19 de la ley modernizan el tratamiento de bases de datos de deudas comerciales (boletines comerciales o DICOM): Supresión de obligaciones prescritas: los responsables de bases de datos crediticias tienen el deber legal directo de suprimir de manera proactiva e inmediata toda información personal de deudas prescritas, sin necesidad de requerimiento del titular u orden de la APDP. Extinción del dato por pago: extinguida la deuda por pago, novación o condonación, el dato financiero debe eliminarse de manera irreversible en el plazo acotado por la ley. Prohibición expresa de discriminación financiera: se prohíbe taxativamente exigir la comunicación de datos económicos o comerciales para procesos de selección laboral, admisión en colegios o universidades, o atención médica de urgencia.

4. Gobernanza avanzada y el Delegado de Protección de Datos (DPO)

La designación de un Delegado de Protección de Datos (DPO) autónomo es mandatoria para los bancos, AFPs, compañías de seguros y fintech que traten de forma sistemática datos sensibles financieros o realicen perfilamiento masivo. Su identidad debe ser pública ante la APDP y los usuarios.

Casos típicos del sector

Situación	Gravedad probable
Una fintech deniega automáticamente un crédito y el cliente no recibe motivo ni forma de reclamar.	Grave
Un boletín comercial mantiene hace años una deuda prescrita porque nadie procesó su eliminación.	Grave
Un banco llena la verificación de identidad con reconocimiento facial, sin evaluación de impacto ni aviso de plazos.	Grave

Régimen sancionatorio

Categoría	Sancción máxima	Ejemplos típicos
Leve	5.000 UTM	Incumplir plazos, no entregar información clara
Grave	10.000 UTM	Tratar datos sin base legal, vulnerar seguridad
Gravísima	20.000 UTM	Uso fraudulento, filtración intencional de datos sensibles

Infraacción	Techo en UTM	Equivalencia aprox.*
Leve	5.000 UTM	~ \$345 millones
Grave	10.000 UTM	~ \$690 millones
Gravísima	20.000 UTM	~ \$1.400 millones

*Valores referenciales con UTM de agosto 2026 (~\$69.000). El valor de la UTM se reajusta mensualmente según IPC.

■ Vigencia plena

1 de diciembre de 2026

■ Notificación de brechas

Sin dilaciones indebidas a la Agencia y a los afectados

■ Delegado de Protección de Datos (DPO)

Generalmente voluntario (Art. 50); obligatorio por excepción legal

■ Reincidencia (grandes empresas)

Hasta 2%–4% de los ingresos brutos anuales

■ Recargo por no subsanar

50% adicional si no corrige en 60 días

Checklist de implementación sectorial

1. Identificar y documentar todos los algoritmos de pricing dinámico o scoring crediticio automatizado
2. Implementar salvaguardas de transparencia y explicabilidad algorítmica en interfaces financieras.
3. Elaborar Evaluaciones de Impacto (DPIA/EIPD) de los sistemas KYC biométricos y modelos
4. Garantizar que no se solicitan antecedentes comerciales en flujos de reclutamiento o selección

Hoja de ruta sugerida de implementación

Días 1–30 · Diagnóstico

Inventario RAT, mapa de flujos de datos y brecha frente a la ley.

Días 31–60 · Adecuación

Políticas actualizadas, contratos DPA, canales ARSOP y banners de consentimiento.

Días 61–90 · Cultura y pruebas

Capacitación, simulacro de brecha, revisión final y designación DPO si corresponde.

Preguntas frecuentes

¿Puedo exigir biometría para operar en la app?

Como alternativa de autenticación si existe opción equivalente, con consentimiento expreso y DPIA; imponerla sin alternativa cuestiona la libre decisión.

¿Cuándo debe desaparecer una deuda pagada del boletín?

Extinta la obligación por pago, novación o condonación, el dato se elimina de manera irreversible en el plazo acotado por la ley y su reglamento.

¿El DPO es obligatorio en fintechs pequeñas?

Es mandatorio ante tratamiento sistemático de datos sensibles financieros o perfilamiento masivo; en la práctica, casi todo actor del rubro califica.

¿Puedo pedir antecedentes comerciales a un postulante a trabajo?

No. Se prohíbe taxativamente exigir datos económicos o comerciales en procesos de selección laboral, admisión escolar o urgencia médica.

¿El pricing dinámico está prohibido?

No está prohibido, pero si decide tasas individualmente de forma automatizada activa las salvaguardas del Art. 8 bis (explicabilidad e impugnación).

Glosario esencial

KYC

Know Your Customer: identificación y verificación del cliente; con biometría implica datos sensibles.

Scoring crediticio

modelo que puntúa el riesgo de pago; si es automatizado, dispara derechos de explicabilidad e impugnación.

Boletín comercial

base de datos de deudas (tipo DICOM) regulada por los Arts. 17-19 con supresión proactiva.

Prescripción

extinción legal de la obligación por transcurso del plazo; opera el borrado del dato asociado.

Pricing dinámico

fijación algorítmica de tasas o primas por perfil individual de riesgo.

ARSOP

Derechos de Acceso, Rectificación, Supresión, Oposición y Portabilidad que todo titular puede ejercer.

APDP

Agencia de Protección de Datos Personales: organismo fiscalizador del nuevo régimen.

RAT

Registro de Actividades de Tratamiento: inventario interno obligatorio de qué datos se tratan, para qué y con quién.

DPA

Data Processing Agreement o contrato de encargo de tratamiento entre responsable y encargado.

DPO

Delegado de Protección de Datos (Art. 50): figura generalmente voluntaria, obligatoria solo por excepción legal.

Brecha de seguridad

Pérdida, robo o acceso no autorizado a datos personales; debe notificarse sin dilaciones indebidas.

MPI

Modelo de Prevención de Infracciones: programa interno de cumplimiento que atenúa sanciones.

UTM

Unidad Tributaria Mensual, unidad monetaria indexada usada para calificar multas (reajustada por IPC).

Fuente oficial

Ley 21.719 — Biblioteca del Congreso Nacional de Chile (idNorma=1209272). Documento orientativo de trabajo; ante dudas específicas consultar siempre el texto vigente.